Kavach AI Platform — Attack Mode Report

Autonomous AI pentester (Recon → Scanner → Exploit → Reporter)

Scan ID: 20261021-062349-b2bfc4
Target: http://127.0.0.1:39357
Generated: 2026-10-21 06:23
Findings: 6
Summary engine: rule-based (offline)

Executive summary

The automated assessment of http://127.0.0.1:39357 identified 6 finding(s): 1 Critical, 3 High, 2 Medium. The highest-impact issues should be remediated first. All testing was performed non-destructively against an authorised local lab.

Findings overview

#	Severity	Title	MITRE ATT&CK
1	Critical	SQL Injection (error-based)	T1190 Exploit Public-Facing Application
2	High	Reflected Cross-Site Scripting (XSS)	T1059.007 Command and Scripting Interpreter: JavaScript
3	High	Exposed sensitive file: /.env	T1552.001 Unsecured Credentials: Credentials In Files
4	High	Admin interface reachable without authentication	T1078.001 Valid Accounts: Default Accounts
5	Medium	Missing HTTP security headers	T1189 Drive-by Compromise
6	Medium	Directory listing enabled	T1083 File and Directory Discovery

Detailed findings

1. SQL Injection (error-based)

Severity: Critical — Critical (9.1)
Location: http://127.0.0.1:39357/search?id=%27
MITRE ATT&CK;: T1190 — Exploit Public-Facing Application (Initial Access)

Description. A single-quote probe triggers a database error, indicating input is concatenated into SQL and the app is injectable.

Evidence. DB error signature observed: 'you have an error in your sql syntax' at http://127.0.0.1:39357/search?id=%27

Proof of concept (safe). Evidence captured during scanning (non-destructive): DB error signature observed: 'you have an error in your sql syntax' at http://127.0.0.1:39357/search?id=%27

Remediation. Use parameterised queries / prepared statements and an ORM; never build SQL by string concatenation. Disable verbose DB errors.

2. Reflected Cross-Site Scripting (XSS)

Severity: High — High (7.4)
Location: http://127.0.0.1:39357?q=%22%3E%3Csvg%2Fonload%3Dalert%28kv7xss%29%3E
MITRE ATT&CK;: T1059.007 — Command and Scripting Interpreter: JavaScript (Execution)

Description. User-supplied input is reflected into the HTML response without encoding, allowing script execution in a victim's browser.

Evidence. Payload reflected unescaped via '?q='. Marker: kv7xss

Proof of concept (safe). The injected payload is returned verbatim inside the HTML response (unencoded). Context: ...dmin You searched for: "><svg/onload=alert(kv7xss)> </body></html>...

Remediation. Context-aware output encoding, a strict Content-Security-Policy, and input validation.

3. Exposed sensitive file: /.env

Severity: High — High (7.5)
Location: http://127.0.0.1:39357/.env
MITRE ATT&CK;: T1552.001 — Unsecured Credentials: Credentials In Files (Credential Access)

Description. A file that commonly contains secrets or source metadata is publicly readable.

Evidence. HTTP 200 at /.env containing sensitive keywords.

Proof of concept (safe). Evidence captured during scanning (non-destructive): HTTP 200 at /.env containing sensitive keywords.

Remediation. Block access to dotfiles/backups at the web server and remove them from the web root; rotate any leaked secrets.

4. Admin interface reachable without authentication

Severity: High — High (8.0)
Location: http://127.0.0.1:39357/admin
MITRE ATT&CK;: T1078.001 — Valid Accounts: Default Accounts (Defense Evasion)

Description. An administrative endpoint is reachable and returns content without an authentication challenge.

Evidence. HTTP 200 at /admin returning admin/dashboard content.

Proof of concept (safe). Evidence captured during scanning (non-destructive): HTTP 200 at /admin returning admin/dashboard content.

Remediation. Require authentication + authorisation on all admin routes, restrict by network, and change default credentials.

5. Missing HTTP security headers

Severity: Medium — Medium (5.3)
Location: http://127.0.0.1:39357
MITRE ATT&CK;: T1189 — Drive-by Compromise (Initial Access)

Description. The application does not send one or more recommended security response headers, leaving it exposed to clickjacking, MIME sniffing, and content-injection attacks.

Evidence. Missing header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options,

Strict-Transport-Security, Referrer-Policy

Proof of concept (safe). Evidence captured during scanning (non-destructive): Missing header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy

Remediation. Add the missing headers (e.g. Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Strict-Transport-Security, Referrer-Policy) at the app or reverse proxy layer.

6. Directory listing enabled

Severity: Medium — Medium (5.3)
Location: http://127.0.0.1:39357/uploads/
MITRE ATT&CK;: T1083 — File and Directory Discovery (Discovery)

Description. The server returns an auto-generated directory index, exposing file names an attacker can harvest.

Evidence. 'Index of' page served at /uploads/

Proof of concept (safe). Evidence captured during scanning (non-destructive): 'Index of' page served at /uploads/

Remediation. Disable automatic directory indexing (e.g. 'Options -Indexes').

All testing was performed non-destructively against an authorised local lab. Kavach refuses targets that resolve outside loopback / private IP ranges.